

1/10

File No.: EXP202311377

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complaining party) filed a complaint with the Spanish Agency for Data Protection on August 6, 2023. The complaint is directed against ASSURED FLEET SERVICES, S.L. with NIF B02846558 (hereinafter, the complained party). The reasons on which the complaint is based are as follows:

The complaining party (a former employee of the complained party) indicates that an employee of the company sent, via email, to another, with a copy to the email addresses of the affected individuals (including that of the complaining party), the names and surnames of the 4 employees of the company who had committed a minor infraction for not attending the medical examination.

Along with the complaint, the following documentation is provided:

- Printout of an email dated 29/06/2023 at 16:17, with a copy to the four employees, stating the following:

"...Attached are the minor infractions of the following workers for not attending the medical examination:

B.B.B.

C.C.C.

A.A.A.

E.E.E.

- Printout of an email dated 29/06/2023 at 16:30, with a copy to the four employees, stating the following:

"Ok, I'm sending them for you to sign"

- Printout of an email dated 29/06/2023 at 20:46, with a copy to the four employees, stating the following:

"Hello, according to what E.E.E. says, he renounced the medical examination. Can it be verified?"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/10

- Printout of an email dated 29/06/2023 at 18:13, with a copy to the four employees, stating the following:

"...Mr. B.B.B. has replied to me that he was on leave during those days. According to what they tell me, F.F.F. was up to date; I attach the justification."

Additionally, four scanned letters addressed to the four mentioned workers for their signature for the purpose of notifying the commission of the infraction (attached to the first email) dated June 28, 2023, indicating among other things, the following:

"By means of this letter, we inform you that we have been informed that on April 20, 2023, you were summoned to attend your MEDICAL REVIEW, having to report to it at 08:15 on Thursday, May 11, 2023..."

...the company is going to impose on this occasion a minor infraction, with immediate effects without suspension of employment and salary, in order to redirect your behavior and make you understand that compliance with the regulation in Occupational Risk Prevention is fundamental, and that it also incurs a cost to the company...

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to the complained party, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations. The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of

October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on 01/09/2023 as evidenced by the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On November 6, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complaining party was admitted for processing.

FOURTH: According to the report obtained from the AXESOR tool on March 20, 2024, the entity ASSURED FLEET SERVICES, S.L. is a XXXX company established in the year 2020, with a business volume of XX.XXX.XXX euros in the year 2022.

FIFTH: On April 12, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the complained party for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified in Articles 83.5 and 83.4 of the GDPR.

SIXTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and after the granted period elapsed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

For the formulation of allegations, it has been verified that no allegations have been received from the party being claimed.

Article 64.2.f) of the LPACAP - a provision of which the claimed party was informed in the agreement to open the procedure - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement about the responsibility attributed, it may be considered a proposal for resolution. In the present case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the claimed party, and the sanction that could be imposed. Therefore, considering that the claimed party has not made allegations regarding the initiation agreement of the file and in accordance with what is established in Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been acted upon, the following facts are considered proven by the Spanish Agency for Data Protection in the present procedure:

PROVEN FACTS

FIRST: A worker from the claimed party sent by email from the address ***EMAIL.1 on 29/06/2023 at 16:17, to another worker of the same with the email address ***EMAIL.2, the names and surnames of four employees of the company who had committed a minor infraction for not attending the medical examination to another, with a copy to the email addresses of the affected parties (including that of the claimant).

Likewise, attached to the email were four scanned letters addressed to the four cited workers for their signature for the purpose of notification of the commission of the infraction, dated June 28, 2023.

SECOND: The recipient replies in an email dated 29/06/2023 at 16:30, with a copy to the four employees, stating that he sends them to the same for signature.

THIRD: The recipient replies by email dated 29/06/2023 at 18:13, with a copy to the four employees, indicating that one of the employees responds that he was on leave, attaching proof.

FOURTH: The recipient sends another email dated 29/06/2023 at 20:46, with a copy to the four employees, indicating that one of the workers states that he renounced the medical examination, questioning whether it can be verified.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data

and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, it was established that there was a processing of personal data, since the claimed party was collecting, recording, organizing, and storing, among others, the following personal data of individuals: name, identification number, and location data, among other processes.

The claimed party carried out this activity in its capacity as the data controller, since it was the one determining the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" as "all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In the case at hand, there is a breach of personal data under the circumstances mentioned above, categorized as a breach of confidentiality. According to the Article 29 Working Party, a "Confidentiality Breach" occurs when there is an unauthorized or accidental disclosure of personal data, or access to it.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR.

On the other hand, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which regulate the security of processing, the notification of a personal data security breach to the supervisory authority, as well as the communication to the data subject, respectively.

III

Principle of Integrity and Confidentiality

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/10

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In the present case, it is established that the personal data of the affected individuals, contained in the database of the respondent party, were improperly exposed to third parties, resulting in a loss of confidentiality.

Therefore, there is a personal data breach, categorized as a breach of confidentiality, resulting from the sending of an email without blind carbon copy to several employees, making the corresponding email addresses accessible, as well as information regarding their medical examinations, including a notification from the respondent party in the name of each employee (among whom is the claimant, at that time an employee of the respondent party) for a minor infraction for not attending the indicated medical examinations.

In accordance with the proven facts of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to the respondent party, for violation of Article 5.1.f) of the GDPR.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total global annual turnover of the previous financial year, opting for the higher amount: a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the limitation period, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a limitation period of three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following: a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/10

V

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected individuals and the level of damage and harm they have suffered (paragraph a): due to the loss of confidentiality of the personal data of four workers, as a result of sending an email containing data related to their health without blind carbon copy.
- The categories of personal data affected by the infringement (paragraph g): in this case, it concerns information about the health of employees, which is specially protected data.

It is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, with respect to the infringement committed by violating what is established in Article 5.1.f) of the GDPR, allows for the imposition of a sanction of €2,500 (two thousand five hundred euros).

VI

Security of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and

organizational measures to ensure the security of processing.

2. When assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/10

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as evidence of compliance with the requirements established in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

In this case, the security measures in place by the respondent to prevent employees from sending emails without blind carbon copy, of which the respondent is the owner, have not been substantiated. As the data controller, it should have implemented security measures and ensured their compliance, a fact that is not recorded in this Agency since they have not responded to the transfer of the complaint sent, nor have they made any allegations regarding the initiation agreement.

Therefore, in accordance with the proven facts available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to the respondent, for violation of Article 32 of the GDPR.

VII

Classification and qualification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"4. Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39, 42, and 43;

For the purposes of the limitation period for infringements, the infringement attributed is subject to a two-year limitation period, in accordance with Article 73 of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year limitation period, which involve a substantial breach of the articles mentioned therein and, in particular, the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/10

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

VIII

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered

that the balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €1,500 (one thousand five hundred euros).

IX

Adoption of measures

In accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified timeframe...”, the respondent is required to demonstrate to this Agency within three months the adoption of the necessary measures to ensure compliance with the provisions of Article 32 of the GDPR, in order to prevent the sending of emails containing personal data without the appropriate blind carbon copy option, without prejudice to any other measures that may arise from the instruction of the procedure.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been substantiated, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ASSURED FLEET SERVICES, S.L., with NIF B02846558, for an infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified in Articles 83.5 and 83.4 of the GDPR, a fine of €2,500 and €1,500 respectively.

SECOND: TO ORDER ASSURED FLEET SERVICES, S.L., with NIF B02846558, that pursuant to Article 58.2.d) of the GDPR, within three months from the date of C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

This resolution shall be firm and enforceable, and the party must prove to this Agency that they have taken the necessary measures to ensure compliance with the provisions of Article 32 of the GDPR, in order to prevent the sending of emails containing personal data without the proper option for blind carbon copy.

THIRD: NOTIFY this resolution to ASSURED FLEET SERVICES, S.L.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must fulfill the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, to the restricted account No. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es